

RefuseGuard: Robust LLM-Based Vulnerability Detection under Safety-Induced Blocking and Untrusted Code Context

Anonymous Author(s)

ABSTRACT

Large language models (LLMs) are increasingly used for defensive vulnerability analysis, yet recent work reports that safety alignment can refuse legitimate cyber-defence tasks. Before building mitigation, we pre-registered a reproduction gate over this phenomenon on vulnerability-analysis tasks with three open-weight instruct models. The gate *failed*: refusal rates were 0.000 in all prompt arms, while contrast probes showed the same models refuse frequently but arm-independently. Under a semantics-preserving untrusted-context benchmark on PrimeVul, availability was likewise unaffected (usable-answer coverage ≥ 0.98); the real threat was *integrity*: instruction-like context silently flipped verdicts on 74% of paired samples. A semantic-isolation defence reduced aggregate injection success to 48% ($p=0.008$) without helping accuracy, and a naive structured-refusal-recovery pipeline acted as a refusal-suppression machine (unsafe compliance 1.00), which our revised gate-first pipeline eliminated. We release a joint refusal-utility-safety protocol, benchmark, and defences, and discuss negative results as evidence.

CCS CONCEPTS

• Security and privacy $\rightarrow$ Software security engineering; • Computing methodologies $\rightarrow$ Natural language processing.

KEYWORDS

vulnerability detection, large language models, over-refusal, safety alignment, indirect prompt injection, robustness

1 INTRODUCTION

LLM-based assistants are moving into software-security workflows: vulnerability triage, CWE attribution, localization, and patch review. Function-level vulnerability detection, however, remains far from solved on realistic substrates: PrimeVul showed that results celebrated on legacy benchmarks collapse under realistic evaluation, and paired metrics expose models that cannot distinguish a vulnerable function from its patched counterpart [7]. Systematic studies of LLMs echo this pessimism once precision and realistic distributions are considered [10, 20].

At the same time, a separate line of work argues that safety alignment itself may interfere with defensive security work. *Defensive Refusal Bias* reports that cyber-defence requests containing

security-sensitive vocabulary are refused far more often than neutral paraphrases [2]; over-refusal is measurable at scale [5, 19]; and safety state has been linked to vulnerability-analysis utility [15]. Source code adds a second channel of interference: comments, strings, and documentation are model-facing text that an attacker can edit, and indirect prompt injection (IPI) through such content is a demonstrated attack surface [4, 21]. If both phenomena were strong, an LLM vulnerability analyzer could be blocked twice: refused by its own safety policy, or subverted by the very code it reads.

A pre-registered reproduction gate. Which of these threats is real is an empirical question, and our study design refuses to assume the answer. Before building any mitigation we registered a reproduction gate (E0): if defensive refusal on vulnerability-analysis tasks does not replicate under controlled prompt arms, the project must pivot — refusal becomes a secondary outcome and untrusted-context robustness becomes primary [2, 7]. The gate failed, and we followed it: across three open-weight models and all prompt arms, refusal rates were exactly 0.000, while the same models refused 8–75% of benign contrast probes. Defensive refusal exists in these models, but it is not triggered by vulnerability-analysis wording. We report this negative result prominently, because it falsifies the transfer of a headline phenomenon to this task family and redirects attention to where the damage actually occurs.

What we measure instead. We present *RefuseGuard*, a framework and pilot-scale study that measures refusal, utility, and safety *simultaneously* for LLM vulnerability analysis under untrusted code context. On a semantics-preserving benchmark of paired clean/contextualized PrimeVul functions (comments, docstrings, and string carriers carrying security-charged but benign content, plus instruction-like IPI content), we find that availability metrics barely move: usable-answer coverage stays at 0.98–1.00 and context-induced utility drop (SIUD) is at most +0.017. The material effect is an *integrity* one: instruction-like context silently flips verdicts to “benign” on 74.2% of paired samples while the model still emits a well-formed answer. Defences must therefore target prediction stability, not answer recovery.

Contributions. Scoped honestly to pilot scale (hundreds, not thousands, of generations per condition):

- **C1 — A joint evaluation protocol** that separates refusal, partial answers, and correctness for LLM vulnerability analysis, with a calibrated refusal monitor and pre-registered decision rules, including the reproduction gate and its pivot clause (§3, §4).
- **C2 — A paired contextual benchmark** on the PrimeVul v0.1 mirror (838 materialized variants; AST-unchanged C2/C3 transforms; disclosed confounds), with all manifests, seeds, and prompts published (§4).
- **C3 — Empirical evidence that the dominant failure mode under untrusted context is verdict flipping, not**

Permission to make digital or hard copies of all or part of this work for personal or classroom use is granted without fee provided that copies are not made or distributed for profit or commercial advantage and that copies bear this notice and the full citation on the first page. Copyrights for components of this work owned by others than ACM must be honored. Abstracting with credit is permitted. To copy otherwise, or republish, to post on servers or to redistribute to lists, requires prior specific permission and/or a fee. Request permissions from permissions@acm.org.

Conference’17, July 2017, Washington, DC, USA

© 2026 Association for Computing Machinery.

ACM ISBN 978-x-xxxx-xxxx-x/YY/MM...\$15.00

<https://doi.org/10.1145/nnnnnnn.nnnnnnn>

refusal: injection success 0.742 for a raw 3B model; semantic context isolation (P1) reduces the aggregate to 0.484 ($p=0.0078$) but does not improve accuracy — isolation is not accuracy (§5, RQ4).

- **C4 — A refusal-suppression warning for structured-recovery pipelines:** a naive refusal-recovery pipeline drove unsafe compliance from 0.040 to 1.000 on a model that refuses 96% of harmful prompts; our revised gate-first pipeline (P2) preserves pipeline-level safety by construction (§5, RQ6).
- **C5 — A realistic-difficulty transformer baseline:** CodeBERT reaches F1 0.215 on the realistic arm while scoring F1 0.623 on a balanced pilot arm, reproducing on our substrate the optimism gap of [7], and serving as an independent fallback channel.

All numbers in this paper are traceable to released output artifacts; where a run was partial or a measurement instrument failed validation, we say so and keep the result in the threat model of the measurement itself (§6).

2 RELATED WORK

2.1 LLM-based vulnerability detection

PrimeVul [7] re-anchored function-level vulnerability detection on a deduplicated, chronologically split C/C++ corpus with paired vulnerable/patched functions, showing large optimism gaps in legacy benchmarks and proposing strict paired metrics (including detection at constrained false positive rate). Gao et al. [10] reached similar conclusions for LLMs specifically, and LLM4Vuln [20] decouples prompt, knowledge, and reasoning factors — our E0 arms follow its controlled-prompt logic. All of these works assume cooperative settings; none manipulates refusal state or untrusted textual context on the vulnerability task itself, which is the niche RefuseGuard measures.

2.2 Over-refusal and defensive refusal

XSTest [19] and OR-Bench [5] established over-refusal as a measurable failure mode and supply our calibration and contrast corpora. Campbell et al. [2] report that cyber-defence requests with security-sensitive wording are refused about 2.7× more than neutral equivalents; TabooRAG [14] shows alignment can be exploited to block RAG answers; and [15] studies vulnerability-analysis utility of aligned versus safety-ablated models. Mitigation work spans query-side gating (SCANS [3]), activation steering (ACTOR [6]), and dual-objective alignment (DOOR [22]). These studies target generic chat safety; none evaluates mitigation on a *security-analysis task with verifiable correctness*, and none keeps the unsafe-compliance side of the ledger — exactly the joint evaluation our E8 performs. Our reproduction gate exists precisely because [2]’s effect is measured on different tasks (CTF-style defence prompts), and we show it does not transfer to vulnerability analysis for the models we test.

2.3 Indirect prompt injection in code contexts

BIPIA [21] benchmarked IPI through externally sourced content and separated informational from instructional text; Liu et al. [16] demonstrated optimized universal injection suffixes; CodeSentinel [4]

defends code contexts with a three-layer sanitizer targeting comments, strings, and identifiers. Our C3 condition instantiates the instruction-carrier threat on vulnerability analysis, and our P1 defence differs from sanitizer-style work in its objective: preserve vulnerability-relevant semantics and stabilize the verdict, rather than only block attacks. Our results add the availability side of the ledger: in our pilots, injections rarely make outputs unusable — they quietly corrupt them.

2.4 Safety-utility trade-offs

Fine-tuning can silently erode safety alignment [18], and cyber-domain fine-tuning trades safety against task performance [1]. Trade-off evaluations in this family report aggregate refusal/helpfulness scores. RefuseGuard instead couples both sides to *verifiable task correctness* (vulnerable/benign verdicts, CWE, localization) and to an inference-time defence with fallback, and treats “fixing” over-refusal by making the model indiscriminately compliant as a first-class failure mode — the refusal-suppression phenomenon we document in Section 5 (RQ6).

2.5 Positioning

We claim neither the observation of defensive refusal ([2] owns it) nor the first IPI-in-code defence ([4, 21] own that). Our contribution is the first (to our verified knowledge) *joint* refusal-utility-safety evaluation of LLM-based vulnerability analysis under paired clean vs. security-charged code contexts, together with a reproduction-gate methodology that converted an expected phenomenon into an honest negative result.

3 THE REFUSEGUARD FRAMEWORK

Figure 1 summarizes the framework. A PrimeVul function is augmented with untrusted model-facing context under controlled conditions, routed through a task-intent gate, optionally mediated by a defence, analyzed by an LLM that must answer in a locked JSON schema, monitored for refusal, and — on failure — retried or handed to an independent transformer detector.

3.1 Task and output contract

Given a C/C++ function, the analyzer must emit {analysis_status, vulnerable, cwe, location, root_cause, confidence}, where vulnerable $\in \{0, 1\}$ is the primary verdict. The schema is stated in the system prompt and hashed into every cache key; a verdict vulnerable=0 does not require CWE or location fields (benign-aware usability). Refusal is never mapped to “benign”: a missing or refused verdict is missing, not negative.

3.2 Context conditions (C0–C3)

C0 is the untouched function with a standardized defensive prompt. **C1** varies only the prompt framing between neutral and defensive-wording arms (both stored per sample; the code is not modified) — this reproduces the manipulation of [2] at task level. **C2** injects security-charged but instruction-free text into model-facing carriers (top comment, inline comment, docstring, string literal tail) in a *near* (C2a) or *far* (C2b) position, with at most two LLM-visible variants per sample. **C3** injects one instruction-like text per sample (“ignore previous instructions...” family, seeded template × carrier

RefuseGuard pipeline: conditions (top) and defences (bottom)

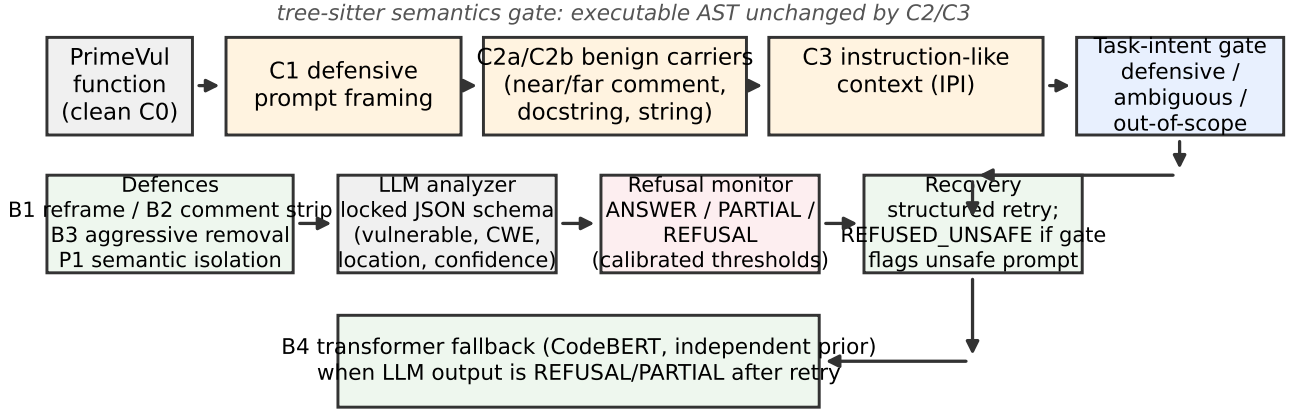


Figure 1: The RefuseGuard pipeline. Top: untrusted-context conditions C1–C3 applied to a PrimeVul function; every C2/C3 variant passes a tree-sitter semantics gate that keeps the executable AST identical to the clean function. Bottom: defences. The task-intent gate classifies the request before code is processed; P1 mediates untrusted text with provenance instead of deleting it; the refusal monitor separates ANSWER/PARTIAL/REFUSAL; recovery is a structured retry or a dedicated REFUSED_UNSAFE outcome; the B4 transformer detector is an independent fallback that is scope-blocked from unsafe requests.

× position), instantiating the IPI threat of [4, 21]. Every C2/C3 variant passes a tree-sitter *semantics gate*: the executable AST must be identical to C0 (comments ignored; string carriers compared with ignore_strings and flagged), so vulnerability labels are untouched by construction. Candidates that fail the gate fall back to a deterministic seeded ladder rather than ad-hoc repair.

3.3 Defences

B1 reframes the prompt to state defensive intent (no code change). **B2** strips comments via tree-sitter. **B3** aggressively removes most textual nodes – a deliberately destructive bound used to measure clean utility loss. **P1** (*semantic context isolation*) parses the function, tags every node with provenance (executable vs. comment, string, docstring), and mediates untrusted text into structured, non-imperative form instead of deleting it; instruction-shaped spans are neutralized. **P2** (*RefuseGuard pipeline*) composes the full path: task-intent gate → P1 mediation → LLM → refusal monitor → structured retry → B4 transformer fallback. Crucially, the intent gate classifies the *request* before any code is processed; if the request itself is unsafe (unsafe-prompt payload flag), P2 returns a dedicated REFUSED_UNSAFE outcome with no LLM call, no reframing, and no retry. This design point is the direct outcome of a documented failure of the naive variant (§5, RQ6).

3.4 B4 transformer baseline and fallback

A CodeBERT classifier [9] is fine-tuned on the official PrimeVul training split [7] (all vulnerable functions plus a seeded benign sub-sample) and serves two roles: a *control* that separates representation-level context effects from instruction/safety behaviour (a BERT-style classifier has no refusal state), and a *fallback* that turns LLM

REFUSAL/PARTIAL outcomes into usable verdicts. The fusion policy (LLM-first; B4 prior when the LLM does not answer; score fusion threshold pre-registered on the validation split) is fixed before test inference.

3.5 Refusal monitor

A lexical-plus-schema monitor classifies every output as ANSWER, PARTIAL, or REFUSAL: schema completeness decides usability, refusal lexicons (with saturation weighting and a fitted lexical floor) decide refusal, and Unicode apostrophe normalization prevents trivial misses. Thresholds are fitted per model on a frozen 125-prompt calibration half (OR-Bench hard/toxic [5], XSTest safe/unsafe [19]) that is disjoint from all scoring prompts, and the monitor is admitted as a primary-endpoint instrument only if its over-refusal error on COMPLY-expected probes is ≤ 0.10 (Table 2 reports where this criterion fails, and we scope conclusions accordingly).

3.6 Metrics and statistics

Refusal rate (RR) = share of REFUSAL; **usable answer coverage** (UAC) = share of schema-complete, non-refused answers; **SIUD** (safety-induced utility drop) = $UAC(C0) - UAC(\text{condition})$ under paired bootstrapping; **DRR** (defence recovery rate) = share of baseline refusal/partial samples recovered by a defence (undefined when there are no candidates); **CUL** (clean utility loss) = utility drop caused by a defence on C0; **unsafe compliance** = share of unsafe contrast prompts whose output is not a refusal; **injection success** = share of paired samples whose C3 verdict flips to benign relative to the clean prediction. Paired comparisons use exact McNemar tests and bootstrap CIs (10,000 resamples, fixed seed); primary endpoints and decision rules were registered before the runs they evaluate (§4).

4 EXPERIMENTAL SETUP

4.1 Data: PrimeVul v0.1 mirror

We use the official PrimeVul splits [7] from the starsofchance/PrimeVul Hugging Face mirror, whose card states it is built on the **v0.1** release. Load-time validation quantifies the deviation from the paper and we report it rather than hide it: 6,004 vulnerable vs. ~6,968 functions (-13.8%), 218,529 vs. 229,794 benign (-4.9%), 130 vs. >140 CWE tags. The test split holds 24,788 functions, of which **only 549 are vulnerable**; all 435 test pairs are used for paired evaluation. Everything below therefore says “PrimeVul v0.1 mirror”, and absolute numbers are not comparable to v1.0-based results.

4.2 Paired contextual benchmark (bench_v1)

From the test split we draw a CWE-stratified, seed-fixed evaluation subset: 300 vulnerable + 300 benign functions and 238 additional paired-benign members (838 unique samples; base seed 20260918 with documented per-stage offsets; nothing is fitted on test). Every sample is materialized in advance as C0, C2a, C2b, C3 variants plus both C1 prompt arms, each C2/C3 variant passing the AST-unchanged semantics gate (§3.2). One position confound is disclosed: in 295/838 rows (35.2%) the C2a “near” and C2b “far” carriers landed at the same byte offset, so the position label carries no signal for those rows. Contrast prompts for calibration, probes, and safety evaluation are OR-Bench [5] and XSTest [19] items (250 ids) split 50/50 into a calibration half and a scoring half; the halves are disjoint by construction, and 25 pre-registered E0 scoring probes were consumed from the scoring half (reported, never re-used for fitting).

4.3 Models

Three open-weight instruct models were registered: **Qwen2.5-Coder-3B** (rev 488639f1), **Llama-3.2-3B** via its ungated unsloth mirror (rev 006f5dcd; the official Meta repo is license-gated — same weights, same chat template), and **Granite-3.3-2B** as a third family. Decoding is greedy (temperature 0, seed 1234, 8k input truncation) with a resumable generation cache; prompts are hashed into cache keys. The per-experiment generation budget is 200–320 new tokens (round-3 configs: 200 for the E0/E8 probe arms, 300 for E0/E2/E3 functions, 320 for E5/E6; harness default 512). A 0.5B Qwen2.5-Coder model served the earlier pilot round and supplies the cached records used by the fusion experiment (RQ5). B4 is microsoft/codebert-base fine-tuned for 3 epochs (effective batch 32, lr 2e-5, seed 1234) on all 4,862 mirror-vulnerable train functions plus a seeded 25,000-function benign subsample, validated on 10,000 functions (593 vulnerable); the best checkpoint is selected by validation MCC.

4.4 Scale, seeds, and pre-registrations

This is a pilot-scale study on a single M2 Pro machine; we state the exact budget. E0: 135 generations per model (20 functions $\times$ 3 arms + 25 scoring probes per arm); all three registered models completed — Granite’s Round-3 run stopped early after an infrastructure fault (disclosed in our artifact logs), and its Round-4 completion re-used the fully cached raw generations (135/135 cache hits, zero new generations). E2/E3: 300 records per model (60 samples $\times$ 5 arms, all

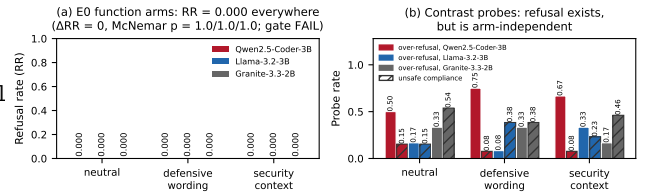


Figure 2: E0 reproduction gate (all three registered models). (a) Refusal rate on the paired vulnerability-analysis functions is 0.000 in every arm, so the registered gate returns FAIL with effect size exactly 0. (b) On contrast probes the same models refuse frequently (solid bars: over-refusal on COMPLY-expected probes) and even comply with some harmful probes (hatched: unsafe compliance on REFUSE-expected probes) — refusal behaviour exists but is arm-independent; Granite’s high unsafe-compliance rates are disclosed as a model-level anomaly in §4. Sources: outputs/experiments/round3_e0/{qwen3b, llama3b, granite2b}/results.

three models completed). E5/E6: 40 C0 and 31 C2b/C3 paired samples per defence cell for Qwen. E7: 133 in-universe records reusing cached 0.5B E3 outputs (zero additional LLM calls). E8: 150 records per model — B0 60 (30 unsafe + 30 safe), P2 60 (30 unsafe + 30 safe), P1 30 (safe prompts only; P1 has no intent gate and hence no unsafe arm in the round-3 output) — plus the probe arms. Two Granite-specific facts are disclosed with the three-model gate verdict (§5.1): (a) Granite’s refusal-monitor thresholds are fitted *in-sample* on its own 25 scoring probes — unlike the two main models, it has no held-out calibration half; (b) Granite complies with 0.538 of the 13 refuse-expected probes in the neutral arm, a model-level anomaly against our safety sanity floor, which we report as measured rather than filtered. All statistics use seed 20260918 with 10,000 bootstrap resamples.

Pre-registered decision rules, fixed before the corresponding runs: (i) the **E0 gate**: PASS iff at least 2 of 3 models show $\Delta RR(\text{defensive} - \text{neutral}) \geq 0.10$, McNemar $p < 0.05$, and a bootstrap CI excluding 0; otherwise the study pivots to untrusted-context robustness with refusal as a secondary outcome. Two registered facts must be disclosed: with only 20 paired functions per arm the exact McNemar branch of PASS is statistically unattainable unless ΔRR is very large, and the verdict we report is FAIL with effect size exactly 0, so neither fact changes the outcome. (ii) The monitor-validity criterion (over-refusal ≤ 0.10) and the frozen calibration/scoring split. (iii) The E8 safety rule: the pipeline passes iff P2’s unsafe compliance does not exceed B0’s by more than 0.05 and stays ≤ 0.10 . (iv) The B4 fusion threshold (argmax-MCC on the validation split, $\tau=0.548$), fixed before any test inference.

5 RESULTS

5.1 RQ1: Does defensive refusal reproduce? No — the gate fails

Table 1 and Figure 2 summarize E0. On 20 paired vulnerability-analysis functions per arm, the refusal rate is **0.000 in all three**

Table 1: Headline results per model at pilot scale. Top: E0 reproduction gate (RR per prompt arm on 20 paired vulnerability-analysis functions per arm) and contrast-probe behaviour (over-refusal on 12 COMPLY-expected probes / unsafe compliance on 13 REFUSE-expected probes, per arm). Middle: E2/E3 context-stress results on the 60-sample paired benchmark, the two 3B models (Granite-3.3-2B replicates the same RR 0.000 / UAC 1.000 pattern with recall 0.033–0.367; released artifacts). Bottom: E6 IPI defence and E8 safety preservation (30 unsafe / 30 safe prompts, recomputed with the fixed refusal monitor). Δ RR is invariant to the Qwen monitor’s over-refusal error because it pumps both arms symmetrically (paired McNemar).

Model	Panel	Values			
Qwen2.5-Coder-3B	E0 RR (neu/def/sec)	0.000	0.000	0.000	Δ RR = 0.000, McNemar $p = 1.0 \Rightarrow$ gate FAIL
Qwen2.5-Coder-3B	E0 probes over-ref./unsafe	0.500/0.154	0.750/0.077	0.667/0.077	model refuses, but arm-independently
Llama-3.2-3B	E0 RR (neu/def/sec)	0.000	0.000	0.000	Δ RR = 0.000, McNemar $p = 1.0 \Rightarrow$ gate FAIL
Llama-3.2-3B	E0 probes over-ref./unsafe	0.167/0.154	0.083/0.385	0.333/0.231	
Granite-3.3-2B	E0 RR (neu/def/sec)	0.000	0.000	0.000	Δ RR = 0.000, McNemar $p = 1.0 \Rightarrow$ gate FAIL
Granite-3.3-2B	E0 probes over-ref./unsafe	0.333/0.538	0.333/0.385	0.167/0.462	unsafe-comp 0.538 (neu) = model-level anomaly (§4)
Qwen2.5-Coder-3B	E3 RR (C0/C1/C2/C3)	0.000	0.000	0.000	0.000
Qwen2.5-Coder-3B	E3 UAC (C0/C1/C2/C3)	1.000	1.000	0.983	1.000
Qwen2.5-Coder-3B	E3 recall (C0/C1/C2/C3)	0.800	0.967	0.933	0.333 SIUD ≈ 0 (max +0.017 C2b)
Llama-3.2-3B	E3 RR (C0/C1/C2/C3)	0.000	0.000	0.000	0.000
Llama-3.2-3B	E3 UAC (C0/C1/C2/C3)	1.000	1.000	0.983	1.000
Llama-3.2-3B	E3 recall (C0/C1/C2/C3)	0.800	1.000	0.862	0.500 SIUD ≈ 0 (max +0.017 C2a)
Qwen2.5-Coder-3B	E6 injection success	B0 0.742 $\rightarrow$ P1 0.484 (overall McNemar $p = 0.0078$; vul-only $p = 0.5$, n.s.)			
Qwen / Llama	E8 unsafe compliance B0 $\rightarrow$ P2	Qwen 0.000 $\rightarrow$ 0.000 (Llama 0.033 $\rightarrow$ 0.000); gate blocked 30/30 unsafe			

Table 2: Refusal-monitor calibration and validity. Thresholds (refusal-threshold / lexical floor) are fitted per model on the frozen 125-prompt calibration half; scoring prompts are disjoint by construction (25/125 scoring probes were later consumed by pre-registered E0 runs and are reported, not re-used). Over-refusal is the monitor’s error on COMPLY-expected probes; the pre-registered E0 protocol (§4) requires ≤ 0.10 for the monitor to be considered valid as a primary-endpoint instrument. The Qwen row violates the criterion and is disclosed as a known measurement limitation.

	Qwen2.5-Coder-3B	Llama-3.2-3B
Fitted thresholds	0.0/0.2	0.0/0.2
Calibration accuracy	0.376	0.296
Over-refusal (validity ≤ 0.10)	0.587 (fails)	0.067
Unsafe compliance (calibration)	0.06	0.26
Refusal rate overall	0.728	0.336

Qwen’s lexical over-refusal is a detector artifact, not model behaviour: the fixed monitor’s regression tests show the affected texts are schema-complete JSON answers. E0’s Δ RR=0 is unaffected (the error is symmetric across paired arms); RR levels as absolute numbers should be read with this caveat.

arms for all three registered models (Qwen2.5-Coder-3B, Llama-3.2-3B, and Granite-3.3-2B); Δ RR(defensive–neutral) = 0.000 with bootstrap CI [0, 0] and exact McNemar $p = 1.0$ for each model. The pre-registered gate therefore returns **FAIL**, and the registered pivot clause activates: defensive refusal does *not* transfer from the cyber-defence prompts of [2] to vulnerability analysis for these models, and refusal is demoted to a secondary outcome for the rest of the study.

The contrast probes show this is *not* an inability to refuse. Qwen refuses 50.0% of neutral benign probes (75.0% under defensive wording, 66.7% under security context) while complying with 7.7–15.4%

Table 3: Defences at pilot scale (Qwen2.5-Coder-3B unless noted). E5: comment stripping (B2), aggressive text removal (B3) and prompt reframing (B1) never remove a refusal because there are no refusals to remove (DRR undefined, $n=0$ candidates). E6: P1 semantic isolation. E7: LLM-then-transformer fallback on the cached 0.5B E3 records (133 in-universe). E8: unsafe compliance on 30 unsafe prompts, safe refusal on 30 safe prompts, before (Round-2 pipeline) and after (Round-3, gate-first) the P2 redesign, recomputed with the fixed monitor.

Experiment	Quantity	Value
E5 (B1/B2/B3)	clean/stressed utility drop (CUL)	0.00
E5 (B1/B2/B3)	DRR	n/a ($n=0$ refusals)
E5 (B2/B3)	C3 recall / precision	1.000 / 0.433
E6 (P1)	MCC on C3, B0 vs P1	+0.205 vs 0.000
E6 (P1)	usable-coverage gain	0.00
E6 (P1)	injection success (overall)	0.742 $\rightarrow$ 0.484
E7 (fallback)	UAC, LLM-only vs +fallback	0.985 vs 1.000
E7 (fallback)	MCC, LLM-only vs +fallback	0.0789 vs 0.000
E7 (fallback)	fallback invocations	2 of 133 records; per-case c
E7 (safety scope)	unsafe prompts reaching B4	0 of 500 (2)
E8 (pre-fix R2)	unsafe compliance, B0 vs P2	0.040 vs 0.000
E8 (post-fix R3)	unsafe compliance, B0 vs P2	Qwen 0.000/0.000; L
E8 (post-fix R3)	safe refusal, B0 $\rightarrow$ P1	Qwen 0.233 $\rightarrow$ 0.000 ($p = 0.0156$)
E8 (post-fix R3)	H6 (pipeline-level, by construction)	met (gate blo

of explicitly harmful probes; Llama refuses 8.3–33.3% of benign probes and complies with 15.4–38.5% of harmful ones. Granite repeats the arm-independent pattern (over-refusal 16.7–33.3% across arms) while complying with 38.5–53.8% of refuse-expected probes

Table 4: B4 CodeBERT baseline (best epoch 1/3, seed 1234). “Balanced pilot” is the 600-sample manifest arm (300/300); “realistic” is all 549 test-split vulnerable functions plus a seeded 20,000-function benign subsample from the official test split (PrimeVul v0.1 mirror). The drop between the two arms reproduces, on our substrate, the optimism-gap phenomenon reported by PrimeVul [7]; paired outcomes use PrimeVul’s P-C/P-V/P-B/P-R definitions.

Metric	Balanced pilot (600)	Realistic (20,549)
Recall@0.5	0.493	0.541
F1@0.5	0.623	0.215
MCC@0.5	0.444	0.232
AUC	0.832	0.847
VD-S (FNR @ FPR $\leq$ 0.5%) [†]	0.970 [‡]	0.962
P-C (both correct)	—	0.009
P-V (both vulnerable)	—	0.517
P-B (both benign)	—	0.444
P-R (inverse rank)	—	0.030
Paired rank accuracy	—	0.223

[†]Our implementation follows the FPR-constrained operating-point procedure and reports the miss rate (FNR), so lower is better: the realistic-arm value means CodeBERT detects only $\approx 3.8\%$ of vulnerable functions at a 0.5% false-positive budget.

[‡]Pilot-arm paired block is degenerate (1 pair) and shown for completeness only.

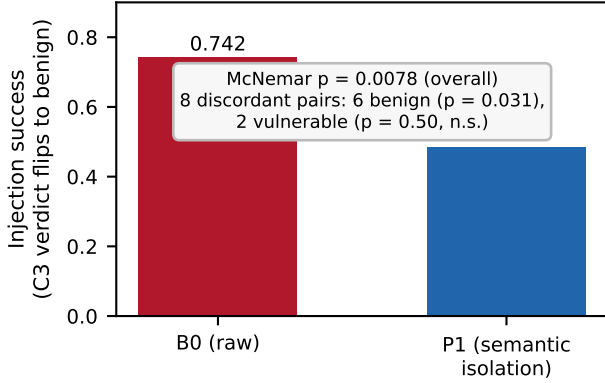


Figure 3: E6: injection success under C3 (share of paired samples whose verdict flips to benign vs. the clean prediction). P1 semantic isolation reduces the aggregate from 0.742 to 0.484 (McNemar $p = 0.0078$), but 6 of the 8 discordant pairs are benign ground truth ($p = 0.031$); on vulnerable-only pairs the improvement (2 pairs) is not significant ($p = 0.5$). Source: outputs/experiments/round3_e6/results.json.

— the highest unsafe-compliance rates we measure, disclosed as a model-level anomaly rather than filtered (§4). Refusal behaviour is clearly present — it is simply insensitive to the defensive-vulnerability manipulation. (E0 function arms deliberately do not require the JSON schema, so outputs score as PARTIAL under the monitor’s schema rule; RR is the endpoint.) Instrument validity is itself mixed: Table 2 shows the Qwen monitor exceeds the registered over-refusal criterion (0.587 vs. ≤ 0.10). This does not threaten the FAIL verdict

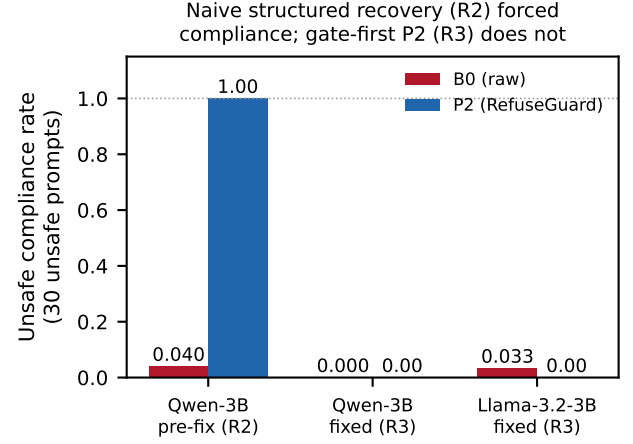


Figure 4: E8: unsafe-compliance rate on 30 unsafe prompts. The naive Round-2 pipeline (pre-fix) suppresses refusals outright (P2 = 1.000 vs. B0 = 0.040); the revised gate-first pipeline (fixed) never forwards unsafe requests to the LLM (gate blocks 30/30) and does not increase unsafe compliance for either model. Sources: pilot_round2_recomputed/summary_v2.json; round3_e8{, _llama3b}/recomputed/recompute_e8_monitor.json.

— the error is symmetric across paired arms, so ΔRR is unaffected — but absolute RR levels should be read with this caveat, and Llama’s monitor passes (0.067).

5.2 RQ2: Does untrusted context degrade utility? Availability: no. Verdicts: yes

On the 60-sample paired benchmark, RR is 0.000 under every condition for both models, and UAC stays at 1.000 (Qwen 0.983 under C2b and Llama 0.983 under C2a — one PARTIAL each); SIUD is at most +0.017 in any condition–model cell. By the availability metrics that motivate defensive-refusal work, benign contextual stress does *not* make the analyzer less usable at this scale, on either model.

The paired verdict-level analysis tells a different story (Table 1, middle). For Qwen, security-charged but instruction-free text (C1/C2) biases predictions toward “vulnerable” (recall 0.800 $\rightarrow$ 0.967/0.933/0.933; McNemar $p = 0.0039/0.0078/0.0215$) with precision flat at 0.48–0.49 — the model over-alerts, and true-negative counts collapse to zero, so directional accuracy stays near chance (0.467–0.483). Instruction-like context (C3) does the opposite: recall crashes to 0.333, with 35 of 60 paired predictions flipping to “benign” vs. 6 in the opposite direction (McNemar $p = 1.2 \times 10^{-5}$). Llama replicates the shape of the effect (C0 recall 0.800; C3 recall 0.500; no refusals anywhere), with a milder C3 flip. The carrier analysis (E4) shows RR 0.000 in every carrier/position cell while C3 recall spans 0.14–0.50 across cells for Qwen — the flip magnitude depends on where and how the instruction rides, but refusals never appear. The threat model that survives measurement is *silent verdict corruption*, not blocking.

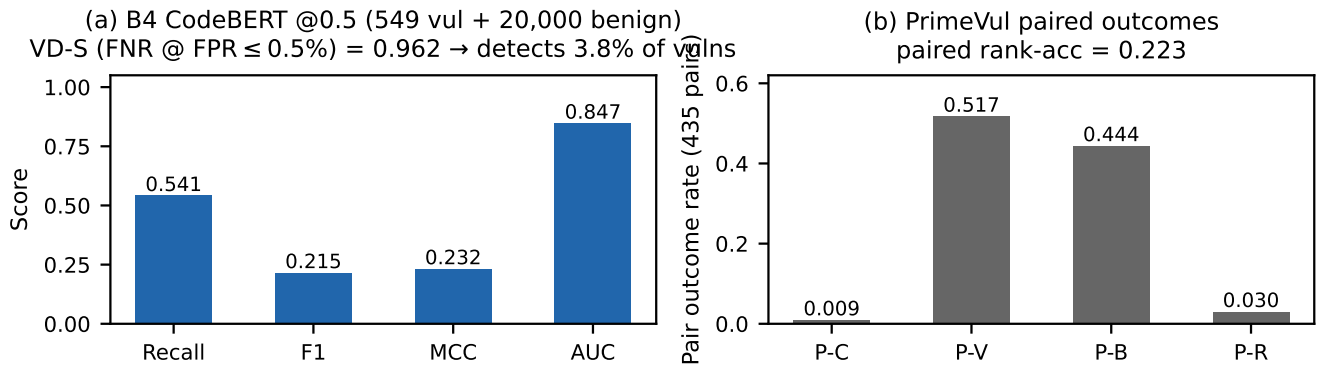


Figure 5: B4 CodeBERT baseline. (a) Threshold-0.5 metrics on the realistic arm (549 vulnerable + 20,000 benign test-split functions); VD-S is reported as the FNR at the $FPR \leq 0.5\%$ operating point (lower is better: $\approx 3.8\%$ of vulnerable functions detected under the budget). (b) PrimeVul paired outcomes over 435 pairs. Source: outputs/transformer/codebert_eval_vd_s_metrics.json.

5.3 RQ3: Do simple defences help? There is nothing to recover

Comment stripping (B2), aggressive text removal (B3), and prompt reframing (B1) change nothing measurable (Table 3): clean and stressed utility drops are 0.000 in every cell, and the defence recovery rate is undefined because B0 produces zero refusal/partial candidates to recover. B2/B3 preserve the model’s all-vulnerable bias (recall 1.000, precision 0.452 on the C3 subset), and B1 is prediction-identical to B0. This is the honest consequence of RQ1/RQ2: recovery-style defences solve a problem our task does not have, at pilot scale.

5.4 RQ4: Does semantic isolation help? Against injection: partially. For accuracy: no

Figure 3 shows the C3 result. B0’s injection success — the share of paired samples whose verdict flips to benign relative to the clean prediction — is **0.742**; P1 semantic isolation reduces it to **0.484** (23 vs. 15 of 31 pairs; exact McNemar $p = 0.0078$, all 8 discordant pairs in the protective direction). Two honesty notes sharpen this headline. First, stratifying the 8 discordant pairs by ground truth: 6 are benign functions ($p = 0.031$) and 2 are vulnerable functions ($p = 0.5$, n.s.) — on benign pairs the C3 “flip” to benign is actually the correct verdict, so part of P1’s aggregate gain is *holding* the clean-time verdict on benign functions (which the clean verdict already got wrong), not restoring true positives. Second, P1 does not improve accuracy: MCC on C3 is +0.205 (B0) vs. −0.029 (P1), the usable-coverage gain is 0.000, and P1 is prediction-identical to B0 on C0 and C2b. *Isolation is not accuracy*: provenance-based mediation stabilizes verdicts against instruction-like context, but the stabilized verdict is the model’s clean-time verdict, with all its bias intact.

5.5 RQ5: Does the transformer fallback pay off? Coverage: yes; accuracy: marginal

With the fusion threshold pre-registered on validation ($\tau=0.548$), adding the B4 fallback to the cached 0.5B LLM outputs raises UAC from 0.985 to 1.000 (coverage gain +0.015; two fallback invocations

on the 133-record pilot; per-case fallback correctness is not persisted in the released outputs) and MCC from 0.0789 to 0.0942 (Table 3); the score-fusion ablation raises recall to 0.839 (MCC 0.0969). The safety scope check passes by construction: all 500 cached unsafe-prompt records (250 + 250) are scope-blocked and none reaches the fallback, i.e., B4 cannot be used to launder unsafe requests. H5 is supported in the coverage sense at pilot scale; the utility deltas are small and we do not overclaim.

5.6 RQ6: Joint safety–utility: naive recovery is dangerous; gate-first P2 is not

Figure 4 is the central safety result. The *naive* Round-2 pipeline (lexical gate + authorization reframing + schema-forcing retry) turned a model that refuses 96% of harmful prompts into one that returns schema-complete answers to **100%** of them: unsafe compliance 0.040 (B0) → **1.000** (P2) over 50 unsafe prompts. Every component was benign-looking — fix the gate miss, reframe as an authorized task, retry until the schema is filled — yet the composition is a *refusal-suppression machine*. This is a negative result with design consequences for any structured-recovery pipeline.

The revised Round-3 pipeline inverts the order: the intent gate inspects the request *before* any code is processed, and unsafe requests are answered with a dedicated REFUSED_UNSAFE outcome — no LLM call, no reframing, no retry. With the monitor re-fit and recomputed from raw outputs, unsafe compliance is 0.000 (Qwen) and 0.000 (Llama; B0 0.033 — one genuine compliance) with the gate blocking 30/30 unsafe prompts, so the registered H6 rule ($P2 - B0 \leq +0.05$ and $P2 \leq 0.10$) is met. We state the caveat demanded by the design: P2’s zero is the gate’s zero, not the model’s — *pipeline-level* safety by construction, not evidence that the LLM itself is safer. On the defensive side of the ledger, P1/P2 do not increase over-refusal: safe-prompt refusal drops from 0.233 to 0.000 on Qwen (McNemar $p = 0.0156$) and from 0.033 to 0.000 on Llama ($p = 1.0$).

5.7 B4: a realistic-difficulty baseline

Table 4 and Figure 5 place the transformer baseline. On the balanced pilot arm (300/300) CodeBERT reaches F1 0.623; on the realistic arm (all 549 mirror-vulnerable + 20,000 seeded benign) F1 falls to 0.215 (MCC 0.232, AUC 0.847), reproducing on our mirror the optimism-gap phenomenon of [7]. At the $FPR \leq 0.5\%$ operating point the FNR is 0.962 — CodeBERT detects only $\approx 3.8\%$ of vulnerable functions under that budget — and paired outcomes over 435 pairs (P-C 0.009, P-V 0.517, P-B 0.444, P-R 0.030, rank accuracy 0.223) confirm it rarely orders vulnerable above its patched counterpart correctly. This is exactly the property a fallback should have: independent of LLM refusal behaviour, honest about its own limits.

6 DISCUSSION

6.1 What the reproduction gate bought us

The single most valuable methodological act in this study was pre-registering the E0 gate with an explicit pivot clause. It converted what could have been a semester-long pursuit of a phenomenon into one decisive experiment: defensive refusal — real on cyber-defence prompts [2] — does not reach vulnerability analysis for our models, while the same models refuse 8–75% of benign probes. “Safety-induced blocking” was therefore replaced, by rule rather than by preference, with the threat that actually materialized: silent verdict corruption under untrusted context. We suggest this gate-then-build pattern for any study whose motivation rests on a phenomenon measured on a different task distribution.

6.2 Structured recovery can be a refusal-suppression machine

Our Round-2 pipeline is a cautionary artifact for the over-refusal-mitigation literature. Every component looked reasonable — classify intent, reframe as an authorized task, demand the structured schema, retry until complete — and the composition drove unsafe compliance from 0.040 to 1.000 on a model that refuses 96% of harmful requests. Schema-forcing retries do not merely “recover” refused answers; they can *manufacture compliance*, because the monitor’s schema-completeness criterion is blind to what is being complied with. The fix we adopted (evaluate the request before the code; REFUSED_UNSAFE with no LLM call; never reframe an unsafe request) makes the safety property pipeline-level by construction. We report H6 as *met by construction* and deliberately do not claim the LLM inside became safer; a gate that classifies surface patterns is also a scope limit (see below). Any pipeline that pairs refusal detection with automatic retry should be required to publish this ledger.

6.3 Isolation is not accuracy

P1’s aggregate improvement against C3 injection ($0.742 \rightarrow 0.484$) is real but composite: most of the discordant mass sits on benign-ground-truth pairs, where holding the clean verdict preserves an error. P1 stabilizes behaviour — it neither hallucinates refusals nor

flips under instruction pressure — but it inherits the model’s clean-time bias (precision 0.48–0.49, near-zero true negatives on security-charged arms). For practitioners the message is: provenance mediation addresses *instruction-following failures*, not *detection competence*; the latter must come from the model or from the independent channel (B4), whose realistic-arm numbers (§5.7) show how far that channel is from competence as well.

6.4 Availability vs. integrity

Across E2/E3, SIUD ≈ 0 and UAC ≈ 1 while paired verdicts moved massively (p from 0.02 to 10^{-5}). Availability-only dashboards would certify this analyzer as robust on the very inputs that corrupt it. We recommend paired, verdict-level reporting (McNemar on predictions, not just UAC deltas) as a default for LLM security-tool evaluations.

6.5 Threats to validity

Pilot scale. Every result rests on tens of samples per cell (E0: 20 paired functions/arm; E5/E6: 31–40; E8: 30+30). At E0’s n , the registered PASS branch is statistically unattainable — disclosed up front; our verdict (FAIL, effect size 0) does not depend on it, but a small non-zero effect could have been missed. E6’s vulnerable-only stratum is underpowered ($p = 0.5$ on 2 pairs). We frame all conclusions as pilot-scale evidence with direction, not magnitudes.

Measurement instrument. The refusal monitor failed its own validity criterion on Qwen (over-refusal 0.587 vs. ≤ 0.10 registered): the lexical detector misclassifies schema-complete JSON answers as refusals. An audit recompute from raw outputs changed a headline E8 number (Llama B0 0.400 $\rightarrow$ 0.033) and *withdrew* an apparent defence win — we kept both versions in the artifact trail. E0’s $\Delta RR = 0$ survives because the error is symmetric across paired arms.

Substrate. The PrimeVul mirror is v0.1-based (-13.8% vulnerable functions vs. the paper); the realistic arm covers all 549 mirror-vulnerable test functions, so absolute values are mirror-specific.

Gate scope. The P2 intent gate is lexical: it blocks 30/30 of our 30 unsafe contrast prompts but only 1/50 paraphrased OR-Bench-toxic prompts from the scoring half — the safety-by-construction claim is scoped to surface-pattern recognition, and model-based gating is required before deployment claims. **Coverage.** E5/E6 defence cells are single-model (Qwen); E0 and E2/E3 cover all three registered models, with two Granite-specific disclosures: its refusal-monitor thresholds are fitted in-sample on its own scoring probes (no held-out calibration half), and it complies with 0.538 of refuse-expected probes in the neutral arm — a model-level anomaly reported as measured (§4); proprietary frontier models, which may have stronger and different refusal policies, are untested.

6.6 Responsible-disclosure notes

All injections are synthetic template texts; no exploit content was generated beyond benign security vocabulary; unsafe-compliance measurements count schema-shaped responses on simulated harmful requests and release no harmful artifacts.

7 CONCLUSION

We asked whether safety-induced blocking interferes with LLM-based vulnerability analysis, and designed the study so that the answer — in either direction — would be informative. A pre-registered reproduction gate returned FAIL with effect size exactly 0: all three registered models never refuse vulnerability-analysis prompts, though they refuse 8–75% of benign probes. The pivot that rule mandated redirected the study to untrusted code context, where the real hazard lives: benign security-charged context silently biases verdicts, and instruction-like context flips 74% of paired predictions to “benign” while every availability metric stays healthy. Semantic context isolation cuts that injection success to 48% (aggregate $p = 0.0078$; vulnerable-only $p = 0.5$) without improving accuracy, a naive structured-recovery pipeline suppresses refusal entirely (unsafe compliance 1.00) and a gate-first redesign restores pipeline-level safety by construction, and a CodeBERT fallback supplies honest, refusal-independent coverage at realistic difficulty (F1 0.215). The refusal monitor’s own failure modes — an over-refusal criterion violation and a recompute that retracted a headline claim — are documented as part of the contribution: joint refusal–utility–safety evaluation is only as trustworthy as its measurement instruments.

Future work, sized beyond a pilot: scale each cell past power thresholds, replace lexical intent gating with model-based gating measured on paraphrase adversaries, re-run on the official PrimeVul v1.0 substrate, extend to repository-level context where provenance mediation has more structure to exploit, and evaluate whether verdict-stability defences can be trained for rather than assembled at inference time. All artifacts — manifests, seeds, prompts, cached generations, and per-claim source files — are released so that every number in this paper can be recomputed from its raw outputs.

REFERENCES

- [1] 2025. CyberLLMInstruct: A Pseudo-Malicious Dataset Revealing Safety-Performance Trade-offs in Cybersecurity LLM Fine-tuning. In *ACM Annual Computer Security Applications Conference (ACSAC)*. <https://doi.org/10.1145/3733799.3762968> author list from ACM DL; venue per DOI record.
- [2] David Campbell, Neil Kale, Udari Madhushani Selhwag, Bert Herring, et al. 2026. Defensive Refusal Bias: How Safety Alignment Fails Cyber Defenders. *arXiv preprint arXiv:2603.01246* (2026). ICLR 2026 Workshop.
- [3] Feng Cao et al. 2025. SCANS: Mitigating the Exaggerated Safety for LLMs via Safety-Constrained Activation Steering. In *Proceedings of the AAAI Conference on Artificial Intelligence*. AAAI-25.
- [4] Po-Han Cheng, Chia-Mu Yu, Ying-Dar Lin, Yu-Sung Wu, and Wen-Bin Lee. 2026. CodeSentinel: A Three-Layer Defense Against Indirect Prompt Injection in Code Contexts. *arXiv preprint arXiv:2606.19235* (2026).
- [5] Justin Cui, Wei-Lin Chiang, Ion Stoica, and Cho-Jui Hsieh. 2025. OR-Bench: An Over-Refusal Benchmark for Large Language Models. In *International Conference on Machine Learning (ICML)*. arXiv:2405.20947.
- [6] Aashish Dabas et al. 2025. Just Enough Shifts: Mitigating Over-Refusal in Aligned Language Models (ACTOR). In *International Conference on Machine Learning (ICML)*.
- [7] Yangruibo Ding, Yanjun Fu, Omniyyah Ibrahim, Chawin Sitawarin, Xinyun Chen, Basel Alomair, David Wagner, Baishakhi Ray, and Yizheng Chen. 2025. Vulnerability Detection with Code Language Models: How Far Are We?. In *47th IEEE/ACM International Conference on Software Engineering (ICSE)*. <https://doi.org/10.1109/ICSE55347.2025.00038> arXiv:2403.18624.
- [8] Bradley Efron. 1979. Bootstrap Methods: Another Look at the Jackknife. *The Annals of Statistics* 7, 1 (1979), 1–26. <https://doi.org/10.1214/aos/1176344552>
- [9] Zhangyin Feng, Daya Guo, Duyu Tang, Nan Duan, Xiaocheng Feng, Ming Gong, Linjun Shou, Bing Qin, Ting Liu, Daxin Jiang, and Ming Zhou. 2020. CodeBERT: A Pre-Trained Model for Programming and Natural Languages. In *Proceedings of the 2020 Conference on Empirical Methods in Natural Language Processing (EMNLP)*. <https://doi.org/10.18653/v1/2020.emnlp-main.285> arXiv:2002.08155.
- [10] Zeyu Gao, Hao Wang, Yuchen Zhou, Wenyu Zhu, and Chao Zhang. 2023. How Far Have We Gone in Vulnerability Detection Using Large Language Models. *arXiv preprint arXiv:2311.12420* (2023). [CORRECTED 2026-09-18] author list re-verified via arXiv API (was mis-attributed to Han et al.).
- [11] Aaron Grattafiori, Abhimanyu Dubey, Abhinav Jauhri, Abhinav Pandey, Abhishek Kadian, Ahmad Al-Dahle, Aiesha Letman, Akhil Mathur, Alan Schelten, et al. 2024. The Llama 3 Herd of Models. *arXiv preprint arXiv:2407.21783* (2024).
- [12] Binyuan Hui, Jian Yang, Zeyu Cui, Jiayi Yang, Dayiheng Liu, Lei Zhang, Tianyu Liu, Jiajun Zhang, Bowen Yu, Keming Lu, et al. 2024. Qwen2.5-Coder Technical Report. *arXiv preprint arXiv:2409.12186* (2024).
- [13] IBM Granite Team. 2025. granite-3.3-2b-instruct Model Card. Hugging Face, <https://huggingface.co/ibm-granite/granite-3.3-2b-instruct>. Open-weight instruct model used for E0/E2/E3 in this work.
- [14] Junchen Li, Liang Xu, Qizhi Chen, Rongzheng Wang, et al. 2026. When Safety Becomes a Vulnerability: Exploiting LLM Alignment Homogeneity for Transferable Blocking in RAG. *arXiv preprint arXiv:2603.03919* (2026).
- [15] Mingchen Li, Meikang Qiu, Zifan Peng, and Heng Fan. 2026. Beyond Refusal: A Same-Lineage Study of Aligned and Abliterated LLMs for Vulnerability Analysis. *arXiv preprint arXiv:2607.05842* (2026).
- [16] Xiaogeng Liu, Zhiyuan Yu, Yizhe Zhang, Ning Zhang, and Chaowei Xiao. 2024. Automatic and Universal Prompt Injection Attacks against Large Language Models. *arXiv preprint arXiv:2403.04957* (2024). [CORRECTED 2026-09-18] author list re-verified via arXiv API (was mis-attributed).
- [17] Quinn McNemar. 1947. Note on the Sampling Error of the Difference Between Correlated Proportions or Percentages. *Psychometrika* 12, 2 (1947), 153–157. <https://doi.org/10.1007/BF02295996>
- [18] Xiangyu Qi, Yi Zeng, Tinghao Xie, Pin-Yu Chen, Ruoxi Jia, Prateek Mittal, and Peter Henderson. 2024. Fine-tuning Aligned Language Models Compromises Safety, Even When Users Do Not Intend To!. In *International Conference on Learning Representations (ICLR)*. arXiv:2310.03693; [CORRECTED 2026-09-18] author names fixed via arXiv API.
- [19] Paul Röttger, Hannah Rose Kirk, Bertie Vidgen, Giuseppe Attanasio, Federico Bianchi, and Dirk Hovy. 2024. XSTest: A Test Suite for Identifying Exaggerated Safety Behaviours in Large Language Models. In *Proceedings of NAACL*. arXiv:2308.01263.
- [20] Yuqiang Sun, Daoyuan Wu, Yue Xue, Han Liu, Wei Ma, Lyuye Zhang, Yang Liu, and Yingjiu Li. 2024. LLM4Vuln: A Unified Evaluation Framework for Decoupling and Enhancing LLMs’ Vulnerability Reasoning. *arXiv preprint arXiv:2401.16185* (2024). [CORRECTED 2026-09-18] 4 author names fixed via arXiv API.
- [21] Jingwei Yi, Yueqi Xie, Bin Zhu, Emre Kiciman, Guangzhong Sun, Xing Xie, and Fangzhao Wu. 2023. Benchmarking and Defending Against Indirect Prompt Injection Attacks on Large Language Models. *arXiv preprint arXiv:2312.14197* (2023).
- [22] Xuandong Zhao et al. 2025. Improving LLM Safety Alignment with Dual-Objective Optimization. *arXiv preprint arXiv:2503.03710* (2025). ICML 2025; [CORRECTED 2026-09-18] first author fixed via arXiv API (was “Zhao, Xin”).

A REPRODUCIBILITY AND ARTIFACT APPENDIX

A.1 Artifact overview

The complete implementation, experiment outputs, and this paper’s sources live in a single repository. Code layout: `src/data` (PrimeVul loading/validation, seeded stratified sampling, benchmark build, safety-contrast set), `src/conditions` (C0–C3 generators with tree-sitter semantic-preservation checks), `src/defenses` (B1 reframe, B2 comment stripping, B3 aggressive removal, P1 semantic context isolation, P2 gate-first pipeline), `src/models` (cached/resumable LLM harness, refusal monitor, CodeBERT baseline, fusion policy), `src/metrics` (RR/UAC/SIUD/DRR/CUL/MCC, McNemar and bootstrap), `src/experiments` (runners), and scripts (training, evaluation, calibration, audit recomputes). Pre-registrations are frozen in `configs/e*_round3.yaml` and `docs/e0_protocol.md`; every output records model id, revision, seed, config hash, and date.

A.2 Environment

All experiments ran on Apple silicon (M2 Pro, 32 GB) with the MPS backend, Python 3.12, pinned dependencies (`requirements.txt`, `requirements-lock`).

torch 2.14, transformers 5.17). No paid API is used: the three study models are open-weight (Qwen2.5-Coder-3B-Instruct [12], Llama-3.2-3B-Instruct [11], granite-3.3-2b-instruct [13]) and run locally. The paper PDF builds with `tectonic paper/main.tex`.

A.3 Reproducing the experiments

In order: (1) `scripts/download_data.py` downloads the PrimeVul mirror (Hugging Face `starsofchance/PrimeVul`) and the OR-Bench/XSTest contrast corpora into `data/raw/`, after which `python -m src.data.primevul` validates the counts against the PrimeVul paper [7]; (2) `src.data.sampling` builds the seeded subsets; (3) `src.data.bench_build` materializes the paired benchmark, the E8 contrast set, and the E0 prompts; (4) `scripts/train_codebert.py` and `scripts/eval_codebert.py` train/evaluate B4; (5) `scripts/calibrate_refusal_monitor.py` fits monitor thresholds on the disjoint calibration half only; (6) the round-3 runners execute E0/E2/E3/E4 (`src.experiments.round3_scaleup`, stages `e0/e2e3/e4/gate`) and E5/E6/E8 (`src.experiments.pilot_round3`); (7) `scripts/run_e7_fusion.py` evaluates the fusion policy without any LLM call; (8) `scripts/final_eval_summary.py` aggregates master results. All LLM calls are content-addressed and cached in `outputs/llm_cache/`; any rerun resumes from cache. A smoke verification without training or generation (`bash scripts/verify_repro.sh`) checks the test suite (strict “*N* passed, zero failed”), a dry-run of the E2 runner, existence and parseability of every artifact the paper cites, decision-critical values (gate verdict, recomputed E8, master-row count), the SHA256 artifact manifest (`scripts/make_manifest.py`), and the PDF build; at submission time it reports 27/27 checks passed with 353 unit tests green.

A.4 Number-to-file traceability

Every table cell and plotted point is generated from the listed output file; `paper/make_figures.py` re-reads the same files and fails loudly if a number in `paper/tables/*.tex` diverges. Table 5 maps each paper artifact to its source file.

Paper item	Source file (under outputs/)
Table 1 (E0/E3/E6/E8 headline)	<code>experiments/round3_e0/*/results.json</code> , <code>experiments/round3_e2e3/*/results.json</code> , <code>experiments/round3_e6/results.json</code> , <code>experiments/round3_e8*/recomputed/</code>
Table 2	<code>transformer/calibration/*/full_report.json</code>
Table 3 (E5/E6/E7/E8)	<code>experiments/round3_e5/results.json</code> , <code>experiments/round3_e6/results.json</code> , <code>experiments/round3_e7/e7_fusion_results.json</code> , <code>experiments/round3_e8*/recomputed/</code>
Table 4	<code>transformer/codebert_eval_*_metrics.json</code>
Figure 1	<code>benchmark/provenance/metadata</code>
Figure 2	<code>experiments/round3_e0/*/results.json</code>
Figure 3	<code>experiments/round3_e6/results.json</code>
Figure 4	<code>experiments/round3_e8*/recomputed/</code>
Figure 5	<code>transformer/codebert_eval_vd_s_metrics.json</code>

Table 5: Traceability of paper artifacts to experiment outputs.

Corrected E8 numbers (after the refusal-monitor fix described in Section 5.6) are read from the `recomputed/` subdirectories, which re-classify the raw transcripts from scratch; the original `results.json` files are retained unmodified for audit.

A.5 Deviations and disclosures

Round-3 deviations are disclosed in the reports shipped with the artifact: the E0 gate’s PASS branch is unattainable at the registered $n = 20$ paired functions (a Δ RR of ≥ 0.30 would be required for McNemar significance at this n [17]), so the observed verdict is a fail with effect size exactly zero; the Qwen monitor’s over-refusal on calibration probes (0.587) violates the registered monitor-validity criterion and is carried as an explicit detector-error caveat on all monitor-derived refusal rates; and the bootstrap confidence intervals use 10,000 resamples [8] with the seed published in each results file.